

Compliance Audit Trail

SOX, HIPAA & PCI-DSS Change Management for VM Migration

Regulated industries require complete audit trails for infrastructure changes. VM migration from VMware to KVM is a significant change event. This guide provides auditor-ready documentation templates, evidence packages, change management workflows, and compliance control mappings for SOX, HIPAA, PCI-DSS, and SOC 2.

SOX | HIPAA | PCI-DSS | SOC 2 | Change Management | Evidence Packages | Auditor-Ready

Compliance Framework Requirements

What auditors expect to see for infrastructure migration changes.

Framework	Key Control	Requirement for Migration	Evidence Required	h2kvmctl Provides
SOX	IT General Controls (ITGC)	Change management process for IT infrastructure changes	Change request, approval, test results, rollback plan	Migration logs, checksum verification, dry-run results
HIPAA	164.312(b) Audit Controls	Audit trail for systems containing ePHI	Who accessed what, when, from where, what changed	JSON audit log with user, action, timestamp, VM name
PCI-DSS	Req 6.4 Change Control	Documented change control for CDE systems	Impact analysis, approval, testing, separation of duties	Dry-run validation, boot test results, conversion report
SOC 2	CC8.1 Change Management	Changes tested, approved, and monitored	Change ticket, test evidence, production deployment log	Full migration log with status, timing, errors
GDPR	Article 32 Security	Maintain security during data processing changes	Data protection impact assessment, encryption evidence	Checksum verification, no data at rest in transit
FedRAMP	CM-3 Configuration Change	Documented change control process	CAB approval, security impact analysis, plan of action	Doctor report, conversion manifest, deployment log

Common Auditor Questions

Questions About the Migration

- "How do you ensure data integrity during conversion?"
- "What change control process was followed?"
- "How were VMs tested before production cutover?"
- "What is the rollback procedure if migration fails?"
- "Who approved the change and when?"
- "Were duties separated (dev/test/deploy)?"

Answers (with h2kvmctl evidence)

- SHA-256 checksums pre/post conversion (manifest.json)
- Change ticket + approval in ITSM (reference in migration log)
- Boot test + smoke test results (automated, logged)
- VMware VMs kept 48 hours; rollback = power on VMware VM
- Approval signatures in change ticket (linked in config YAML)
- CI/CD pipeline: validate→convert→test→deploy with approval gates

Change Management Workflow

ITIL-aligned change management process for VM migration.

Change Control Process

Phase	Activity	Role	Tasks	Artifacts	Duration
1. Request	RFC Submission	Migration Lead	Submit RFC with scope, timeline, risk assessment, rollback plan	Change Request Form	Day 1
2. Assess	Impact Analysis	Infra + Security	Review VM dependencies, data classification, compliance impact	Impact Assessment Doc	Days 2-3
3. Approve	CAB Review	CAB Members	Review RFC, assess risk, approve/reject/defer	CAB Minutes, Approval	Day 4
4. Plan	Implementation Plan	Migration Lead	Detailed steps, test cases, rollback procedure, comms plan	Implementation Plan	Days 5-7
5. Test	Pre-Production	QA / Migration	Dry-run conversion, boot test, application smoke test	Test Results Report	Days 8-10
6. Execute	Production Migration	Migration Team	Execute migration per plan, log all actions	Migration Log	Weekend
7. Verify	Post-Migration	App Owner + QA	Validate all services, performance baseline, sign-off	Verification Report	Day after
8. Close	PIR / Closure	Migration Lead	Post-implementation review, lessons learned, close ticket	PIR Document	Day +3

Separation of Duties

Requester (Migration Lead) != **Approver** (CAB/Manager) != **Implementer** (Migration Engineer) != **Verifier** (QA/App Owner). For SOX compliance, no single person should request, approve, implement, and verify a change. h2kvmctl CI/CD pipelines enforce this with role-based approval gates.

Migration Evidence Package

Complete evidence bundle for auditors — generated automatically by h2kvmctl.

Evidence Package Contents

```
migration-evidence/
├── 01-change-request/
│   ├── RFC-2026-0042.pdf           # Change request form (from ITSM)
│   ├── impact-assessment.pdf       # Risk and impact analysis
│   └── cab-approval.pdf             # CAB meeting minutes + approval
├── 02-pre-migration/
│   ├── doctor-report.json          # h2kvmctl doctor output
│   ├── vm-inventory.csv            # Source VM list with specs
│   ├── dry-run-results.json        # h2kvmctl --dry-run output
│   └── network-topology.yaml       # VLAN/bridge mapping
├── 03-migration-execution/
│   ├── migration-log.json          # Full h2kvmctl execution log
│   ├── per-vm/
│   │   ├── db-server.json         # Individual VM conversion report
│   │   ├── app-server.json
│   │   └── web-server.json
│   ├── checksums.json             # SHA-256 pre/post conversion
│   └── timeline.json              # Start/end time per VM
├── 04-testing/
│   ├── boot-test-results.json      # Automated boot verification
│   ├── smoke-test-results.json     # Application-level tests
│   ├── performance-baseline.json   # Before/after performance
│   └── network-validation.json     # Connectivity verification
├── 05-post-migration/
│   ├── verification-signoff.pdf    # App owner sign-off
│   ├── rollback-status.txt         # "VMware VMs retained for 48hr"
│   └── pir-report.pdf              # Post-implementation review
└── manifest.json                  # Package index with SHA-256 of all files
```

Generating Evidence Package

```
# h2kvmctl generates evidence automatically
h2kvmctl convert \
  --config migration.yaml \
  --evidence-dir /data/evidence/RFC-2026-0042/ \
  --change-ticket RFC-2026-0042 \
  --json
```

Creates all JSON artifacts above

Per-VM Conversion Report

```
{
  "vm_name": "db-server",
  "change_ticket": "RFC-2026-0042",
  "timestamp": "2026-03-23T02:15:30Z",
  "operator": "jsmith",
  "source": {
    "format": "vmdk",
    "path": "/data/exports/db-server.vmdk",
```

```
# Add manual documents (approval PDFs)
# Generate manifest:
h2kvmctl evidence-package \
  --dir /data/evidence/RFC-2026-0042/ \
  --sign --gpg-key auditor@company.com
```

```
"size_bytes": 107374182400,
"sha256": "a1b2c3d4..."
},
"output": {
  "format": "qcow2",
  "path": "/var/lib/libvirt/images/db-server.qcow2",
  "size_bytes": 42949672960,
  "sha256": "e5f6a7b8..."
},
"fixes_applied": ["fstab", "initramfs"],
"boot_test": "pass",
"duration_seconds": 340,
"status": "success"
}
```

SOX Compliance Controls

IT General Controls (ITGC) mapping for Sarbanes-Oxley compliance.

SOX ITGC Control Mapping

Control ID	Control Area	Control Description	Migration Evidence	Test Procedure
ITGC-CM-01	Change Mgmt	All changes follow documented process	RFC form, CAB approval, implementation plan	Verify RFC exists for each migration wave
ITGC-CM-02	Testing	Changes tested before production deployment	Dry-run results, boot test log, smoke test	Review test results match success criteria
ITGC-CM-03	Approval	Changes approved by authorized personnel	CAB minutes with approval signatures	Verify approver is authorized (not requester)
ITGC-CM-04	Rollback	Rollback procedure documented and tested	Rollback plan, VMware VMs retained for 48hr	Verify rollback was tested in pre-prod
ITGC-AC-01	Access Control	Migration access restricted to authorized	sudo logs, SSH key audit, user list	Verify only migration team has root access
ITGC-AC-02	Separation	Duties separated (request/approve/implement)	User logs showing different users for each	Verify no single user performed all roles
ITGC-LM-01	Logging	All changes logged with timestamp and user	h2kvmctl migration log (JSON), syslog	Review logs cover all migration activities
ITGC-LM-02	Integrity	Data integrity verified post-change	SHA-256 checksums, application validation	Verify checksums match expected values

HIPAA Migration Controls

Protecting electronic Protected Health Information (ePHI) during migration.

HIPAA Safeguard Mapping

Administrative Safeguards

- **164.308(a)(1):** Risk analysis — migration risk assessment completed before RFC
- **164.308(a)(5):** Security awareness — migration team briefed on ePHI handling
- **164.308(a)(6):** Incident response — plan for migration failure with ePHI exposure
- **164.308(a)(8):** Evaluation — post-migration security evaluation within 30 days
- **Evidence:** Risk assessment doc, training records, incident response plan, evaluation report

Technical Safeguards

- **164.312(a):** Access control — only authorized personnel access ePHI VMs during migration
- **164.312(b):** Audit controls — all access to ePHI systems logged
- **164.312(c):** Integrity — SHA-256 checksums verify data not altered
- **164.312(d):** Authentication — SSH keys + sudo, no shared accounts
- **164.312(e):** Transmission security — encrypted transfer (TLS/SSH)
- **Evidence:** audit.log, checksums.json, SSH key list, encryption verification

Physical Safeguards

- **164.310(a):** Facility access — data center access log during migration
- **164.310(c):** Workstation security — migration console in secured area
- **164.310(d):** Device controls — secure media handling for USB transfers
- **Evidence:** Badge access logs, workstation inventory, media disposal records

ePHI Data Classification

```
# VM classification for migration priority
# migration-hipaa.yaml
vms:
  - name: ehr-database
    data_class: ePHI
    hipaa_controls: full
    migration_window: "Sunday 02:00-06:00"
    pre_migration:
      - risk_assessment: RFC-2026-0042-RA
      - baa_verified: true
    post_migration:
      - access_audit: required
      - penetration_test: within_30_days

  - name: billing-app
    data_class: ePHI
    hipaa_controls: full

  - name: dev-server
```

data_class: non-ePHI
hipaa_controls: standard

PCI-DSS Change Control

Requirements 6.4 and 11.2 for cardholder data environment changes.

PCI-DSS v4.0 Control Mapping

Req	Control	Migration Compliance	Evidence
6.4.1	Dev/test/prod separation	Migration tested in non-prod first; prod migration in separate wave	Wave 0 (dev/test) results → Wave 1 (prod) approval gated on Wave 0 success
6.4.2	Separation of duties	Different personnel for development, testing, production	CI/CD pipeline logs showing different approvers at each stage
6.4.5	Change control procedures	RFC, impact analysis, approval, test, rollback documented	Complete evidence package (see Page 3)
6.4.6	Security patches current	KVM hosts fully patched before receiving CDE VMs	SCAP scan results for target KVM hosts, patch compliance report
10.2	Audit trail	All actions on CDE systems logged with user, time, action	h2kvmctl migration.log + libvirt audit events + syslog
10.3	Log protection	Logs protected from tampering, retained 12 months	Log forwarding to SIEM, log rotation with integrity checks
11.2	Vulnerability scanning	Post-migration vulnerability scan of KVM hosts and VMs	OpenSCAP or Nessus scan results within 7 days of migration
12.5	Quarterly review	Quarterly review of migrated infrastructure security	Review meeting minutes, security posture assessment

CDE Scope During Migration

During migration, both VMware and KVM environments are in PCI scope until VMware VMs are fully decommissioned. Minimize this dual-scope period by migrating CDE VMs in a single wave with immediate VMware decommission. Document the scope reduction in your next PCI-DSS assessment.

Audit-Ready Log Format

Structured logging that meets auditor expectations for every compliance framework.

JSON Audit Log Schema

```
{
  "event_id": "evt-2026-03-23-001542",
  "timestamp": "2026-03-23T02:15:42.123Z",
  "event_type": "vm_migration",
  "action": "convert",
  "status": "success",
  "change_ticket": "RFC-2026-0042",
  "operator": {
    "username": "jsmith",
    "uid": 1001,
    "source_ip": "10.0.1.50",
    "auth_method": "ssh_key"
  },
  "subject": {
    "vm_name": "db-server",
    "source_format": "vmdk",
    "source_path": "/data/exports/db-server.vmdk",
    "source_sha256": "a1b2c3d4e5f6...",
    "target_format": "qcow2",
    "target_path": "/var/lib/libvirt/images/db-server.qcow2",
    "target_sha256": "f7e8d9c0b1a2...",
    "data_classification": "PCI-CDE"
  },
  "details": {
    "fixes_applied": ["fstab", "initramfs", "network"],
    "boot_test": "pass",
    "duration_seconds": 340,
    "source_size_gb": 100,
    "output_size_gb": 40
  },
  "host": {
    "hostname": "kvm-host-01",
    "ip": "10.0.1.11",
    "os": "Rocky Linux 9.3"
  }
}
```

Log Integrity Protection

SIEM Integration

- Forward to SIEM in real-time (rsyslog → Splunk/ELK)
- Hash chain: each log entry includes hash of previous
- Write-once: logs on append-only storage or WORM
- Rotation: logrotate with SHA-256 checksums per file
- Retention: 12 months (PCI-DSS), 6 years (SOX), 6 years (HIPAA)
- Access: read-only for auditors, append-only for system

```
# rsyslog forward to SIEM
# /etc/rsyslog.d/hyper2kvm.conf
module(load="imfile")
input(type="imfile"
      File="/var/log/hyper2kvm/migration.log"
      Tag="h2kvmctl"
      Severity="info"
      Facility="local6"
)
local6.* @@siem.company.com:514

# Splunk HEC
h2kvmctl convert --config migration.yaml \
  --webhook https://splunk:8088/services/collector \
  --webhook-token $HEC_TOKEN
```

Auditor Checklist & Templates

Ready-to-use checklists for internal audit and external assessor review.

Pre-Audit Checklist (Internal)

#	Check Item	Status	Evidence Location	Notes
1	Change request filed for each migration wave		ITSM: RFC-2026-0042	One RFC per wave or one master RFC
2	Risk assessment completed and signed		evidence/01-change-request/	Include data classification impact
3	CAB approval obtained before execution		evidence/01-change-request/cab-approval.pdf	Timestamp must precede migration start
4	Dry-run completed successfully		evidence/02-pre-migration/dry-run-results.json	Zero errors in dry-run output
5	Migration logs collected and complete		evidence/03-migration-execution/	Per-VM JSON with checksums
6	Boot tests passed for all VMs		evidence/04-testing/boot-test-results.json	100% pass rate required
7	Application smoke tests passed		evidence/04-testing/smoke-test-results.json	App owner verified functionality
8	SHA-256 checksums verified (pre/post)		evidence/03-migration-execution/checksums.json	Source integrity maintained
9	Post-migration verification signed by app owner		evidence/05-post-migration/verification-signoff.pdf	Signed within 48 hours
10	Vulnerability scan completed (post-migration)		evidence/05-post-migration/scan-results.pdf	Within 7 days for PCI, 30 days for HIPAA
11	VMware VMs decommissioned per plan		evidence/05-post-migration/decommission-log.json	After 48-hour rollback window
12	PIR completed and lessons documented		evidence/05-post-migration/pir-report.pdf	Within 5 business days

Compliance = Evidence. h2kvmctl Generates Evidence Automatically.

Every h2kvmctl operation produces structured JSON logs with timestamps, operator identity, checksums, and action details. The evidence package template provides auditors with everything they need in one directory. Combine with your ITSM change tickets and CAB approvals for a complete audit trail. Migration from VMware to KVM can be the most well-documented infrastructure change your auditor has ever reviewed.